UNIT 2 · TOPIC 2.1

Security Foundations: CIA Triad

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following best describes a social engineering attack?

- ○ A. An adversary uses a port scanner to enumerate open services on a target server.
- ○ B. An adversary sends a fraudulent email impersonating a bank to trick an employee into revealing login credentials.
- ○ C. An adversary intercepts encrypted network traffic between two hosts to capture session tokens.
- ○ D. An adversary exploits a buffer overflow in a web application to execute arbitrary code.

2. An organization's intellectual property is exfiltrated after a prolonged, covert intrusion traced to a foreign government agency. Which type of adversary best characterizes this threat actor?

- ○ A. Nation-state actor
- ○ B. Insider threat
- ○ C. Script kiddie
- ○ D. Hacktivist

3. During which phase of a cyberattack does an adversary collect information about a target organization, such as employee email formats, public IP ranges, and exposed services?

- ○ A. Reconnaissance
- ○ B. Lateral movement
- ○ C. Exploitation
- ○ D. Exfiltration

4. An adversary researches a target company's social media to identify employee names and job roles, then builds a custom malicious email attachment tailored to the company's HR department. Which two consecutive phases of the cyberattack lifecycle are represented, in order?

- ○ A. Exploitation → Lateral movement
- ○ B. Reconnaissance → Weaponization
- ○ C. Weaponization → Delivery
- ○ D. Delivery → Exploitation

5. A security team discovers that a customer database server is running an unpatched version of its database software, and that adversaries are actively exploiting that exact vulnerability in similar organizations. A breach would expose 200,000 customer records and trigger regulatory fines. After identifying these facts, what is the most appropriate next step in the risk assessment process?

- ○ A. Immediately apply the available patch to eliminate the vulnerability before completing the assessment.
- ○ B. Notify law enforcement of the ongoing threat campaign affecting the industry.
- ○ C. Document the likelihood and impact of exploitation to produce a risk rating for this asset.
- ○ D. Transfer the risk by purchasing a cyber liability insurance policy.

6. An employee reuses their work email password on a personal shopping website. The shopping site is breached and plaintext passwords are leaked publicly. Which statement best explains how password reuse converts a personal breach into organizational cybersecurity risk?

- ○ A. The leaked shopping site password becomes a new threat that directly attacks the organization's firewall.
- ○ B. Password reuse creates a vulnerability in the employee's work account that a threat actor can exploit using the leaked credential, generating risk to organizational assets.
- ○ C. The breach reduces risk to the organization because the adversary already has what they want from the shopping site.
- ○ D. Password reuse is a threat, not a vulnerability, because it is an action taken by the employee rather than a weakness in a system.

7. A NIST risk assessment of a regional hospital finds: (1) adversaries actively and frequently target healthcare organizations; (2) the hospital's electronic health record (EHR) system has not received a security patch in 18 months; (3) a confirmed breach would trigger HIPAA penalties, patient harm lawsuits, and reputational loss. Which evaluation of this risk is most consistent with NIST risk assessment methodology?

- ○ A. Low priority, the EHR system is behind the hospital's perimeter firewall, reducing exposure.
- ○ B. Moderate priority, the threat is real but likelihood is reduced because healthcare breaches are usually opportunistic, not targeted.
- ○ C. High priority, high threat frequency combined with a known unpatched vulnerability and severe multi-dimensional impact places this risk in the highest tier.
- ○ D. Indeterminate, a risk rating cannot be assigned without first completing a full asset inventory.

8. An organization relies solely on a perimeter firewall for network protection. An adversary bypasses it by convincing an employee to click a malicious link in a spear-phishing email, installing a remote access tool on the employee's workstation. The adversary then moves freely through the internal network for three weeks undetected. Which fundamental weakness of a single-control strategy does this scenario most precisely expose?

- ○ A. Perimeter firewalls cannot inspect HTTPS traffic, making all encrypted attacks undetectable.
- ○ B. User awareness training is always more effective than technical controls at preventing phishing.
- ○ C. A single control layer, when bypassed through an alternative attack vector, leaves no remaining detection or containment capability.
- ○ D. Remote access tools are always classified as malware and should be blocked at the firewall by default.

9. A threat intelligence report describes a hacktivist group targeting energy companies: they first conduct open-source reconnaissance to identify exposed industrial control systems (ICS), then launch DDoS attacks to disrupt operations. An analyst must brief leadership on the risk. Which analysis is most accurate and complete?

- ○ A. The group represents a low-sophistication threat because DDoS tools are widely available and require minimal technical skill.
- ○ B. The group is likely a nation-state actor using hacktivist branding, because the two-phase approach indicates advanced persistent threat (APT) characteristics.
- ○ C. The reconnaissance phase meaningfully increases attack effectiveness by enabling the adversary to target specific ICS exposure points rather than launching undifferentiated attacks.
- ○ D. The group's primary motivation is financial gain, consistent with typical hacktivist objectives.

10. Which of the following is an example of a technical security control?

- ○ A. Requiring all employees to complete annual cybersecurity awareness training.
- ○ B. Deploying an intrusion detection system (IDS) to monitor network traffic for malicious activity.
- ○ C. Issuing a written policy prohibiting the use of personal devices on the corporate network.

- ○ D. Conducting background checks on new employees before granting system access.

11. An organization determines that a specific vulnerability has a very low probability of exploitation and that the cost of mitigation significantly exceeds any potential loss. Which risk management strategy is most appropriate?

- ○ A. Risk avoidance
- ○ B. Risk transfer
- ○ C. Risk acceptance
- ○ D. Risk reduction

12. A company installs security cameras at all building entrances, requires an access badge to enter server rooms, and uses a man-trap at the data center door. These are all examples of which control category?

- ○ A. Technical controls
- ○ B. Administrative controls
- ○ C. Physical controls
- ○ D. Operational controls

13. An organization implements multi-factor authentication (MFA) for all remote access connections. Which statement best explains how MFA mitigates the risk of unauthorized access through compromised credentials?

- ○ A. MFA prevents adversaries from discovering employee usernames through open-source reconnaissance.
- ○ B. MFA eliminates the risk of credential-based attacks by replacing passwords with biometric authentication entirely.
- ○ C. MFA makes a stolen or guessed password alone insufficient to authenticate, because a second independent factor is also required.
- ○ D. MFA detects and blocks brute-force login attempts in real time.

14. A security team deploys email filtering to block phishing messages, endpoint protection software on all user devices, and network segmentation to isolate critical servers from the general office network. Which security strategy do these three controls together illustrate?

- ○ A. Principle of least privilege
- ○ B. Security through obscurity
- ○ C. Defense in depth
- ○ D. Zero-trust architecture

15. A company's web application is built on a framework that is no longer supported and cannot be patched. Leadership proposes three responses: (1) migrate the application to a supported framework; (2) purchase cyber liability insurance; (3) decommission the application permanently. Which risk management strategies do options 1, 2, and 3 represent, respectively?

- ○ A. Risk acceptance, risk reduction, risk avoidance
- ○ B. Risk avoidance, risk reduction, risk transfer
- ○ C. Risk transfer, risk acceptance, risk reduction
- ○ D. Risk reduction, risk transfer, risk avoidance

16. A NIST security audit of an organization reveals: the perimeter firewall's access control lists are excessively permissive; endpoint antivirus signature databases are six months out of date; no network segmentation exists between the corporate LAN and production servers; and security awareness training is conducted once every two years. Which assessment of the organization's defense-in-depth posture is most accurate?

- ○ A. Controls exist at multiple layers but each is severely degraded, creating exploitable gaps that an adversary could chain together to achieve full network compromise.
- ○ B. The outdated antivirus is the sole critical weakness; the remaining controls are functioning adequately.
- ○ C. Network segmentation is unnecessary given that a perimeter firewall already restricts external traffic.
- ○ D. The organization has a sound defense-in-depth strategy because controls are present at all four layers.

17. A risk assessment identifies that an organization's primary threat is credential theft via phishing enabling access to cloud-hosted business applications. The team proposes four controls: (1) MFA on all cloud applications; (2) email filtering with malicious-link sandboxing; (3) physical access locks on the on-premises server room; (4) annual security awareness training. Which combination most directly addresses the identified threat model, and why is the excluded control less relevant?

- ○ A. Controls 2, 3, and 4; MFA (1) does not prevent the initial phishing delivery that enables credential theft.
- ○ B. Controls 1, 2, and 4; physical access locks (3) do not address a credential-based attack targeting cloud applications.
- ○ C. Controls 1 and 3 only; training and email filtering introduce human error into the control chain.
- ○ D. All four controls equally address the identified threat because any security control improves overall posture.

18. A NIST risk assessment of a mid-sized financial organization identifies three active vulnerabilities: employees are susceptible to spear-phishing (social engineering vector); the internal network is flat with no segmentation between workstations and core financial systems (network vector); and critical servers are six months behind on patches (software vulnerability vector). The security team has budget to implement exactly two new controls this quarter. Which combination best applies defense-in-depth principles to the highest-impact vulnerabilities?

- ○ A. Deploy a new perimeter firewall and install physical security cameras at all building entrances.
- ○ B. Commission a full penetration test and hire one additional security analyst.
- ○ C. Implement email filtering with integrated user awareness training, and deploy network segmentation between workstations and financial systems.
- ○ D. Enable full-disk encryption on all employee laptops and require badge access to the server room.